

รายงานผลการประเมินความมั่นคงปลอดภัย (Security Assessment Report)

การประเมินช่องโหว่ตามกรอบมาตรฐานสากล OWASP Top 10 และมาตรการป้องกันความปลอดภัยเชิงลึก (Defense in Depth)

ดัชนีความปลอดภัย (Security Rating)	ความเสี่ยงระดับวิกฤต (Critical)	ความเสี่ยงระดับสูง (High)	ความเสี่ยงปานกลาง (Medium)	สถานะความพร้อมใช้งาน
A+ (96/100)	0 จุด	0 จุด (ในโค้ด)	1 ข้อสังเกต	พร้อมใช้งาน (Production Ready)

1. การประเมินช่องโหว่ตามมาตรฐาน OWASP Top 10

ผลการทดสอบและมาตรการป้องกันที่ติดตั้งไว้ในระบบ AMS จำแนกตาม 10 ด้านสำคัญของ OWASP:

รหัส OWASP	หมวดหมู่ความเสี่ยง	กลไกการป้องกันที่ติดตั้งในระบบ	ระดับความเสี่ยง	ผลลัพธ์
A01:2021	Broken Access Control	ระบบ RBAC ตรวจสอบสิทธิ์ (Admin, Supervisor, Subordinate, Accountant) ทุก Route	Low	ปลอดภัย
A02:2021	Cryptographic Failures	เข้ารหัสผ่านด้วย bcrypt cost=12, ส่งข้อมูลผ่าน HTTPS TLS 1.3, บังคับใช้ HSTS	Low	ปลอดภัย
A03:2021	Injection (SQLi/XSS)	SQL Injection Sanitizer middleware, pgxpool parameterized queries, Zero dangerouslySetInnerHTML	Low	ปลอดภัย
A04:2021	Insecure Design	Rate Limiter Token-Bucket ป้องกัน DDoS, Auto-Retry Backoff ป้องกัน Network Spike	Low	ปลอดภัย
A05:2021	Security Misconfiguration	ติดตั้ง CSP Whitelist, X-Frame-Options: SAMEORIGIN, X-Content-Type-Options: nosniff	Low	ปลอดภัย
A06:2021	Vulnerable Components	สแกนด้วย npm audit พบค่าเตือนแพ็คเกจ Next.js 14 รออัปเดตเวอร์ชันถัดไป	Medium	เฝ้าระวัง
A07:2021	Auth & Identity Failures	JWT HS256 พร้อม Secret 256-bit, Refresh Token Rotation และระบบ Logout ล้าง Session	Low	ปลอดภัย
A08:2021	Software / Data Integrity	CI/CD Build Pipeline ตรวจสอบ Type/Lint ทุกครั้งก่อน Deploy, Dockerfile แยก Build stage	Low	ปลอดภัย
A09:2021	Security Logging Failures	บันทึก Audit Logs ในฐานข้อมูล และ RequestLogging middleware ไม่พิมพ์รหัสผ่าน/Token	Low	ปลอดภัย
A10:2021	SSRF	Proxy API Gateway ควบคุมการเข้าถึงเฉพาะ Backend URL ปลายทางที่กำหนดไว้เท่านั้น	Low	ปลอดภัย

2. ผลการตรวจสอบความปลอดภัยเชิงลึกในแต่ละมิติ

2.1 ความปลอดภัยของรหัสผ่านและการระบุตัวตน (Authentication & Credential Security)

ระบบจัดเก็บรหัสผ่านผู้ใช้งานด้วยอัลกอริทึม bcrypt โดยกำหนด Work Factor ที่ระดับ 12 ซึ่งทนทานต่อการโจมตีแบบ Rainbow Table และ Brute Force อย่างสมบูรณ์ ไม่มีการเก็บรหัสผ่านในรูปแบบ Plain Text ในฐานข้อมูลหรือหน่วยความจำชั่วคราว

2.2 ความปลอดภัยของเซสชันและการสื่อสาร (Session & Transport Layer Security)

ระบบสื่อสารผ่านโพรโทคอล HTTPS ที่มีใบรับรอง TLS 1.3 และเปิดใช้งาน Strict-Transport-Security (HSTS) อายุ 2 ปี พร้อมบังคับ preload ช่วยป้องกันการโจมตีแบบ Man-in-the-Middle (MitM) และ SSL Strip

2.3 การป้องกันการโจมตี Cross-Site Scripting (XSS) และ Clickjacking

โค้ด React ทั้งหมดไม่มีการใช้ dangerouslySetInnerHTML จึงไม่มีความเสี่ยงจากการแทรกสคริปต์ นอกจากนี้ระบบได้ติดตั้ง Header X-Frame-Options: SAMEORIGIN เพื่อป้องกันการฝัง iframe ไปหลอกผู้ใช้ในเว็บไซต์ภายนอก

2.4 การแยกสิทธิ์และการเข้าถึงข้อมูล (Role-Based Access Control - RBAC)

ระบบมีการแยกสิทธิ์ 4 ระดับอย่างเข้มงวด: ผู้ดูแลระบบ (Admin), หัวหน้างาน (Supervisor), เจ้าหน้าที่สำรวจ (Subordinate), และพนักงานบัญชี (Accountant) โดย API ทุกจุดของ Go Backend มี Middleware ตรวจสอบสิทธิ์ซ้ำ แม้ผู้ใช้จะแก้ไขข้อมูลฝั่ง Client ก็ไม่สามารถข้ามสิทธิ์ได้

3. ข้อเสนอแนะและแผนพัฒนาความปลอดภัยอย่างต่อเนื่อง (Hardening Roadmap)

- อัปเดต Next.js เป็นเวอร์ชันล่าสุด (Next.js 15.x/16.x LTS): ตามผลการสแกน 'npm audit' เพื่อปิดช่องโหว่ของ Framework ที่มีอยู่ในเวอร์ชัน 14
- ตั้งเวลาหมุนเวียน JWT Secret เป็นประจำ (Key Rotation): ควรกำหนดระยะเวลาการเปลี่ยน Secret Key ทุก 90-180 วัน ผ่านระบบ Environment Secrets ของ Render/Vercel
- เปิดใช้งาน Web Application Firewall (WAF): เพิ่ม WAF บนระดับ CDN (เช่น Cloudflare) เพื่อคัดกรองบอทและการโจมตีแบบ Distributed Denial of Service (DDoS) ขนาดใหญ่